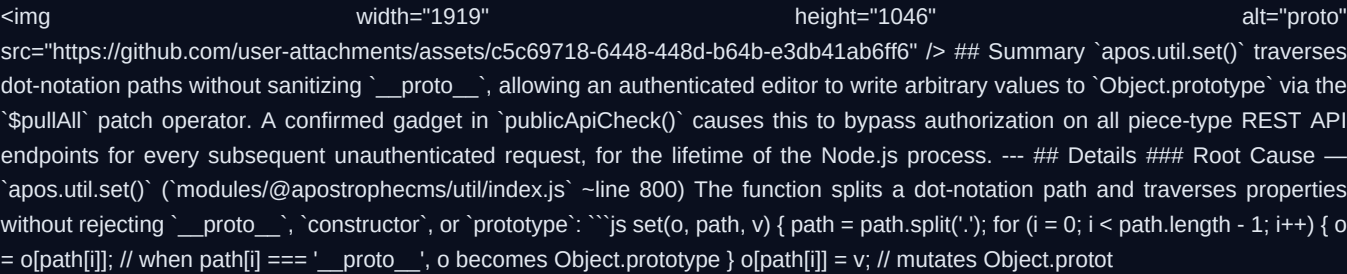


Apostrophe has Server-Side Prototype Pollution in apos.util.set via patch operators that leads to process-wide authorization bypass

Report Type: Weekly · Generated: August 01, 2026 10:30 UTC · Coverage: Jul 31 - Aug 01, 2026

1 Total Advisories	1 Critical	0 High	0 Medium
CRITICAL Severity	9.1 CVSS / Risk Score	TLP:CLEAR TLP Classification	PRO Customer Tier

Executive Summary

Summary `apos.util.set()` traverses dot-notation paths without sanitizing `\_\_proto\_\_`, allowing an authenticated editor to write arbitrary values to `Object.prototype` via the `\$pullAll` patch operator. A confirmed gadget in `publicApiCheck()` causes this to bypass authorization on all piece-type REST API endpoints for every subsequent unauthenticated request, for the lifetime of the Node.js process. --- Details #### Root Cause — `apos.util.set()` (`modules/@apostrophecms/util/index.js` ~line 800) The function splits a dot-notation path and traverses properties without rejecting `\_\_proto\_\_`, `constructor`, or `prototype`: ``js set(o, path, v) { path = path.split('.'); for (i = 0; i < path.length - 1; i++) { o = o[path[i]]; // when path[i] === '__proto__', o becomes Object.prototype } o[path[i]] = v; // mutates Object.protot

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary			
Apostrophe has Server-Side Prototype Pollution in apostrophe via p0.1	Critical	9.8	24.0%	\$2.4M - \$12M Breach Cost Range (FAIR)	\$5.8M IBM Cost of Breach 2025 Median	\$1.2M/day Business Interruption Cost	\$850K Regulatory Fine Exposure
---	---	---	---				

Critical severity breaches trigger mandatory 72-hour regulatory disclosure (GDPR Art. 33), class-action exposure, and long-tail legal costs averaging 18-36 months post-incident.

Remediation Cost Estimate: \$380K · Includes engineering time, IR retainer activation, forensic investigation, and customer notification costs.

Regulatory & Compliance Implications

Organizations processing this advisory must evaluate obligations under applicable regulatory frameworks. The table below maps this threat to relevant compliance requirements.

Framework	Reference	Obligation
GDPR	Art. 33 / Art. 83(4)	72-hour breach notification to DPA; fines up to 4% of global annual turnover
PCI-DSS v4.0	Req. 6.3 / 6.4	Critical patches within 1 month; compensating controls required
NIS2 Directive	Art. 23	Early warning within 24h; full incident report within 72h

Framework	Reference	Obligation
SOX / ICFR	Section 302 / 404	Material cybersecurity weakness disclosure in 10-K/10-Q
ISO 27001:2022	A.8.8 / A.5.29	Documented vulnerability management and incident management

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for Apostrophe has Server-Side Prototype Pollution in apos.util.set via patch operators that leads to process-wide authorization bypass.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK techniques.
4. Apply vendor patch for Apostrophe has Server-Side Prototype Pollution in apos.util.set via patch operators that leads to process-wide authorization bypass immediately - check NVD for official fix guidance.
5. Enable enhanced logging and alerting on all systems running affected software versions.
6. Deploy the Sigma detection rule from this report into your SIEM platform (Sentinel / Splunk / Elastic).
7. Audit all internet-facing instances of affected products and confirm patch deployment.

Appendix - Report Metadata & Legal

Field	Value
Report ID	intel--fad5e1536975f09604d47ff5
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v166.0 GOD-MODE
Generated At	2026-08-01T10:30:35.83056
Customer Tier	PRO
Customer Email	-
TLP	TLP: CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries: enterprise@cyberdudebivash.com

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY